简行安全自评报告

评估对象为2026年10月28日整理的参赛交付版本，运行环境为合成金融沙箱。自评结论：原型具备权限分级、授权绑定、资金预检和记忆隔离控制，可用于本地演示与评审，尚不满足真实银行生产接入条件。本报告属于项目自评，不是第三方认证。

1 评估范围与方法

检查FastAPI接口、Agent工具边界、LangGraph任务状态、业务网关、SQLite账本、Chroma索引、模型Key配置和前端结果展示。证据来自源码、自动化测试及66题冻结诊断评测。离线测试与真实模型语义评分分开报告，单次通过不代表长期可靠。

2 权限分级实现

控制	已实现内容	核查位置
用户身份与所有权	登录Token、会话有效期、本人计划和资源检查	security.py、engine.py、workspace.py
角色读取范围	按用户、会话、角色及来源组装上下文	context_builder.py、memory.py
GREEN YELLOW RED	只读允许、用户确认、敏感操作强验证	bank_rules.py、engine.py
授权与版本绑定	指纹绑定本次对象和参数，变化后重新授权	security.py、engine.py
资金写入	确定性服务、事务、幂等键和回执	operations.py、services/、adapters.py
运行限制	期限、取消、调用次数与请求Token预算	harness.py、token_budget.py、chat_tasks.py

GREEN/YELLOW/RED是操作分级，不能将其理解为三个可切换的账户身份。demo管理员权限不授予替他人交易的能力。动态出金阈值为沙箱规则，真实接入需替换为银行规则。

3 已知风险清单

编号	风险及影响	当前控制与后续处理	优先级
R01	演示账户、验证码用于体验，不适合互联网开放	默认仅本机访问，公开部署前关闭演示开关并接入正式身份系统	高
R02	第三方模型接收必要业务上下文	当前仅合成数据，真实接入前做脱敏、最小化和服务商评估	高

编号	风险及影响	当前控制与后续处理	优先级
R03	提示注入与隐蔽凭证仍可能绕过文本检测	不可信资料隔离、Schema校验与独立授权网关兜底，持续扩展攻击测试	高
R04	SQLite、文件锁和本地Key不适合跨主机部署	当前限定单机，后续迁移主库并接入密钥管理服务	高
R05	auth.key与数据库同时泄漏可能暴露加密凭证	本地访问控制，备份分离，生产需集中密钥管理和轮换	高
R06	登录与公开接口的生产级防刷和网络防护尚不完整	保持本地沙箱，公网前增加限速、网关、TLS及安全审查	高
R07	两道任务的用户可见回应仍不完整	保留失败样本，不改判，按下文继续修复并回归	中
R08	外部产品资料可能过期或缺条款	保留来源和更新时间，未知项显式说明，实际办理重新核验	中
R09	单次66题评测与开发题集存在偏差	公布口径与失败，补独立保留集、多次运行和人工复核	中
R10	本地审计哈希链不能抵抗同时改写数据与校验值	当前用于一致性检查，生产需外部不可变审计存储	中
R11	浏览器端会话及前端依赖仍需持续加固	限定可信演示环境，公网前补CSP、依赖扫描和XSS专项检查	中

“高”表示真实生产接入前必须处理，不表示已在演示中观察到资金损失。风险状态以“已有控制但仍有限制”或“尚待生产化”理解，不把后续计划写成已完成能力。

4 两项保留的功能问题

public_fund_code_followup：系统保留基金公司与代码，但对赎回到账、费用和股票风险的分项回应不足。现有资料不够时，应分别给出未知项和补充入口，不能编造条款。

complex_c08：系统保留会员按月付条件，但回复与界面没有明确显示“按月付”。需要完善已填条件的统一展示。该题没有被从分母中剔除。

5 检查证据

tests/test_safety.py、test_memory_conflicts.py、test_chroma_memory.py、test_token_budget.py、test_personal_model_settings.py、test_lite66_repairs.py等覆盖权限、授权、记忆与恢复边界。完整测试结果见测试说明及JUnit记录。66题冻结诊断结果为64题严格通过、2题失败，五维加权分4.7431/5，资金与授权不变量未发现违规。有限测试无法证明不存在其他风险。

6 后续验收门槛

真实接入前完成银行身份与权限对接、真实适当性与清算规则、独立渗透与隐私评估、模型数据使用审查、服务端限流与告警、跨主机事务一致性和灾难恢复演练。完成后重新评估风险，不沿用当前沙箱结论。